OWASP SWITZERLAND

From APIs to Agents

OWASP as a Unified Prioritization Lens

Dante Hollingsworth · Cloud Solution Architect, Microsoft
Ibraimo Djalo · Solution Engineer, Microsoft



INTRODUCTION

Your speakers



Dante Hollingsworth
Cloud Solution Architect
Microsoft



Ibraimo Djalo
Solution Engineer
Microsoft

One lens across seven OWASP Top 10 lists — from APIs to agents

SESSION OVERVIEW

Objectives and agenda

01 Use OWASP guidance to prioritize security initiatives objectively

02 Identify security investments that reduce risk across multiple technology domains

03 Focus limited resources on the controls that provide the greatest security impact

04 Establish a consistent approach to securing resources within and across technology domains

AGENDA

01 Introduction

02 Shared security challenges

03 Security frameworks to the rescue?

04 Let's get creative: OWASP as a compass

05 Takeaways

Shared challenges, now accelerated

01 THE CONSTANT SQUEEZE

Capacity
Lack of people, processes and tools

Budget
Limited budgets for every security initiative

Security team

Scope
Broad scope of technology, platforms and processes

Velocity
Threat volume and speed outpace capabilities

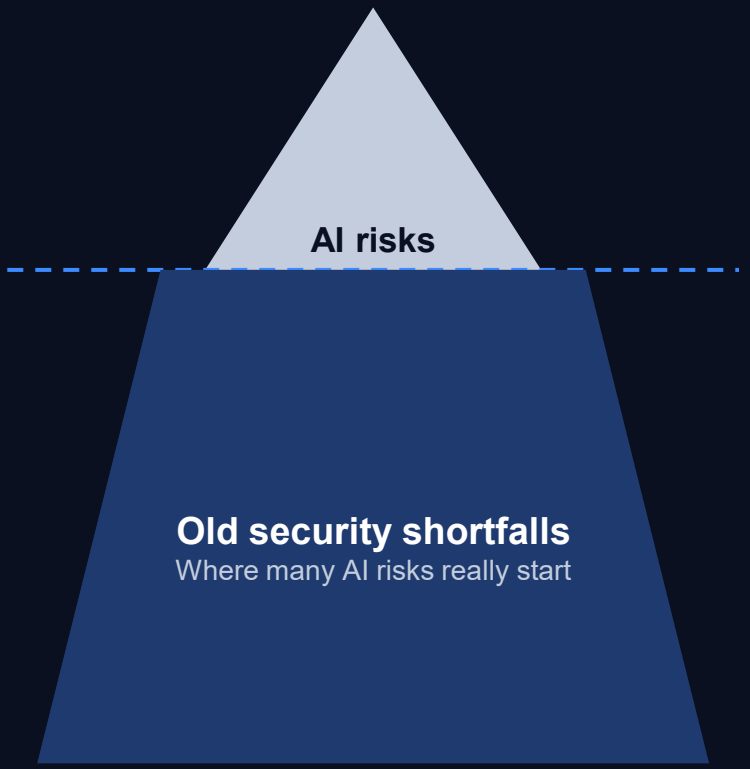
02 RISE OF THE MACHINES

More to govern
AI security and governance add to the struggle

New knowledge
Every security team needs new skills

Speed of change
Outpaces classic security review and response

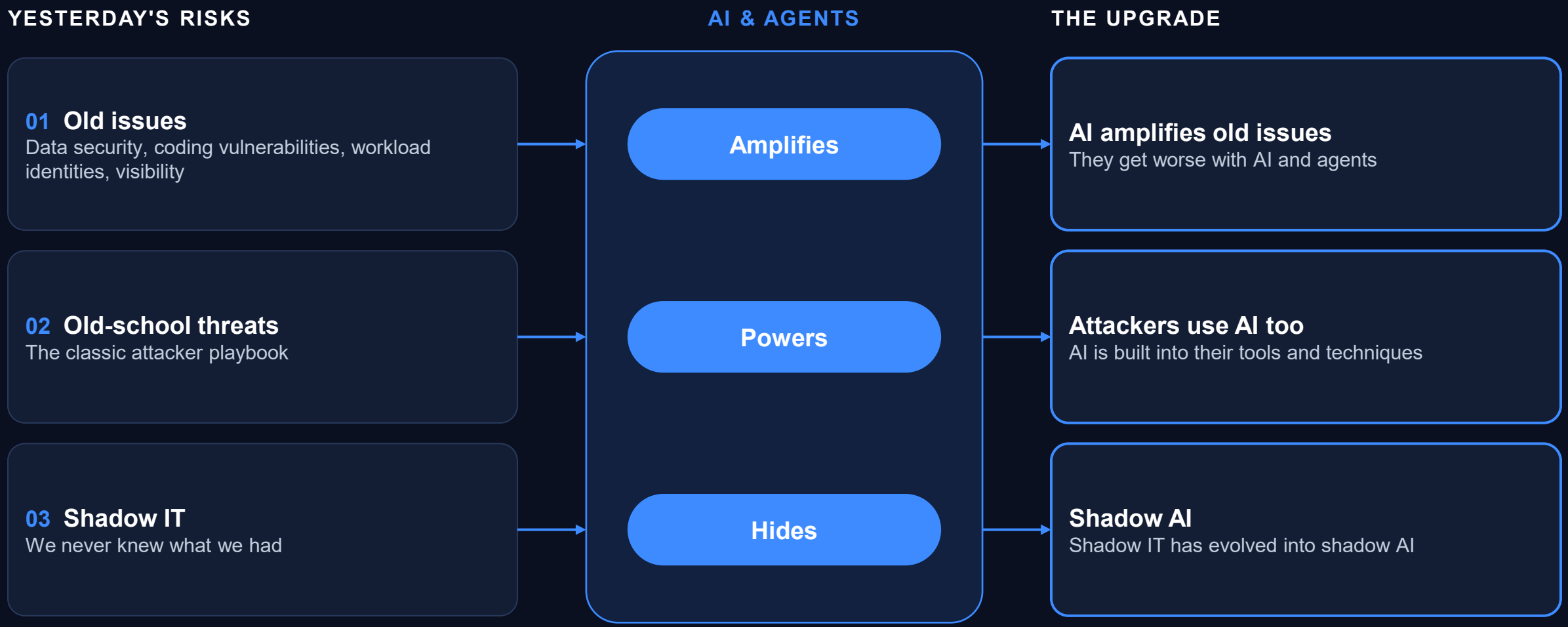
03 OLD ROOTS



What we see is new. What sinks us is old.

SHARED SECURITY CHALLENGES

Old risks get an upgrade



A framework for everything

01 THE PROMISE

We have a framework for that!

NIST
Risk & standards anchor

CSA
Cloud security controls

CIS
Cyber-hygiene baseline

OWASP
App security standard

Each one has a clear purpose: structure for security risk and a standard start for policy and control design.
…and one for nearly every technology or discipline.

02 THE PILE-UP

Overlapping controls
Repetition across frameworks

Too much guidance

Too many mitigations

Too many risks

Security team

Instead of relief, more pressure

03 THE QUESTION

How should we use these frameworks?

Checklists?

Requirements?

Commandments?

Or… a different way of reading them

OWASP TOP 10 RISKS

So much excellent OWASP guidance

Web | API | CI/CD | NHI | MCP | Agentic AI | LLM

7	70	200+	500+	100s
Top 10 areas	risks	risk examples	highlighted risks	of mitigations

Feeling overloaded?

Controls and risks overlap across technologies
Where do we start? How do we start?
We need a plan.

OWASP AS A COMPASS

Connect the dots

01 SEVEN LISTS

- Web
- API
- CI/CD
- NHI
- MCP
- Agentic AI
- LLM

02 THE COMPASS



1 Map — Threats and mitigations across all seven lists. AI can help

2 Reuse — The map for control definitions, threat modeling and more

3 Prioritize — Controls that reduce risk across multiple frameworks

03 THE DESTINATION

~~Seven OWASP programs~~

~~Seven review checklists~~

Risk reduction
One plan that works across all seven lists

Avoid checklist hell.
Invest first where one control cuts risk in many places.

OWASP AS A COMPASS

Five OWASP meta risks

Mapping connections across OWASP standards consolidates risks into five control domains — buckets of shared risks and standard mitigations.

1

Identity, Authentication & Access Control

Connected risks
15

2

Supply Chain & Dependency Security

Connected risks
14

3

Data, Secrets & Credential Protection

Connected risks
9

4

Integrity, Injection & Trust Boundaries

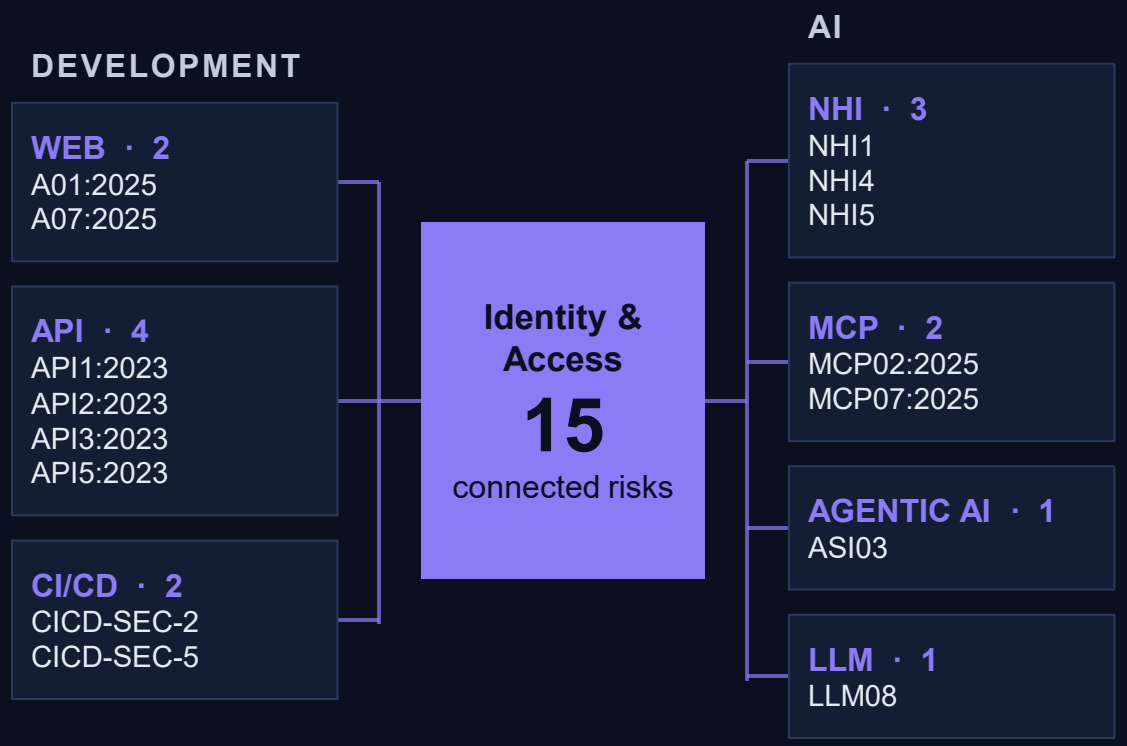
Connected risks
16

5

Secure Operations, Visibility & Resilience

Connected risks
15

Identity, Authentication & Access Control



DEVELOPMENT RISK · WEB + API + CI/CD — **8 connected**

Excess access, weak authentication and privileged pathways expose data, functions and production.

- Strong authentication
- Least privilege
- Fine-grained authorization
- Workload identity
- Privileged access controls

AI RISK · NHI + LLM + MCP + AGENTIC AI — **7 connected**

Excess privilege turns a compromised model, tool, identity or agent into an authorized path in.

- Identity for every workload & agent
- Least-privilege agency
- Scoped tool authorization
- Short-lived credentials
- Lifecycle management
- Human oversight

Prioritized mitigations

01

Centralize and standardize access control

- Use a common identity provider and consistent authorization policies where feasible
- Detect anomalous behavior for both users and NHI

02

Detect identity and access flaws early in the developer workflow

- Code scanning, CI/CD security testing, AI-assisted review
- Make code output and quality part of the same process

03

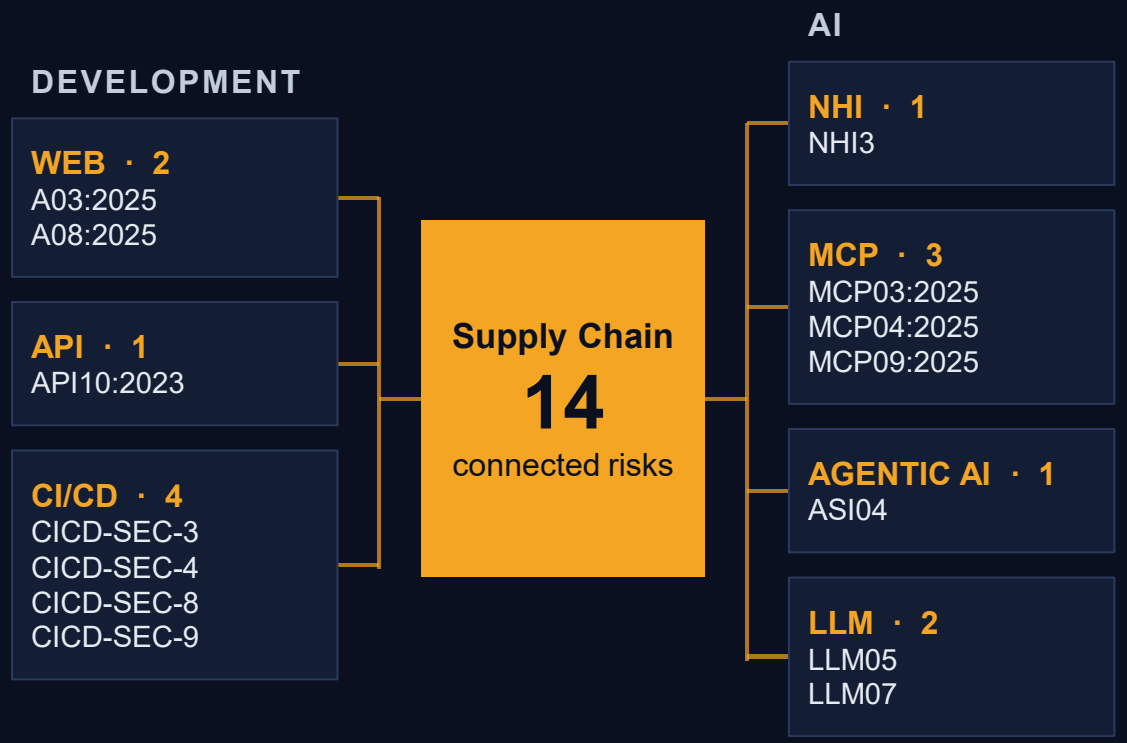
Apply least privilege by default

- Reusable RBAC policies less permissive than platform defaults
- Use the identity controls your platform already offers

PRIORITIZE

Least privilege + strong identity

Supply Chain & Dependency Security



DEVELOPMENT RISK · WEB + API + CI/CD — **7 connected**

Vulnerable dependencies, untrusted APIs, pipelines or tampered artifacts become part of your app.

- Inventory dependencies
- Control trusted sources
- Protect CI/CD
- Verify integrity & provenance
- Govern third parties & integrations

AI RISK · NHI + LLM + MCP + AGENTIC AI — **7 connected**

Models, data, plugins, MCP servers, tools and agents are all dependencies — one can steer the AI.

- Inventory the AI ecosystem
- Establish trusted sources
- Verify provenance & integrity
- Apply least privilege
- Control dynamic dependencies
- Continuously monitor

Prioritized mitigations

01

Continuously inventory dependencies

- Restrict trusted sources
- Apply least privilege to dependencies

02

Protect the build pipeline

- Detect vulnerable, malicious or unexpected dependency changes
- Pin and securely update dependencies

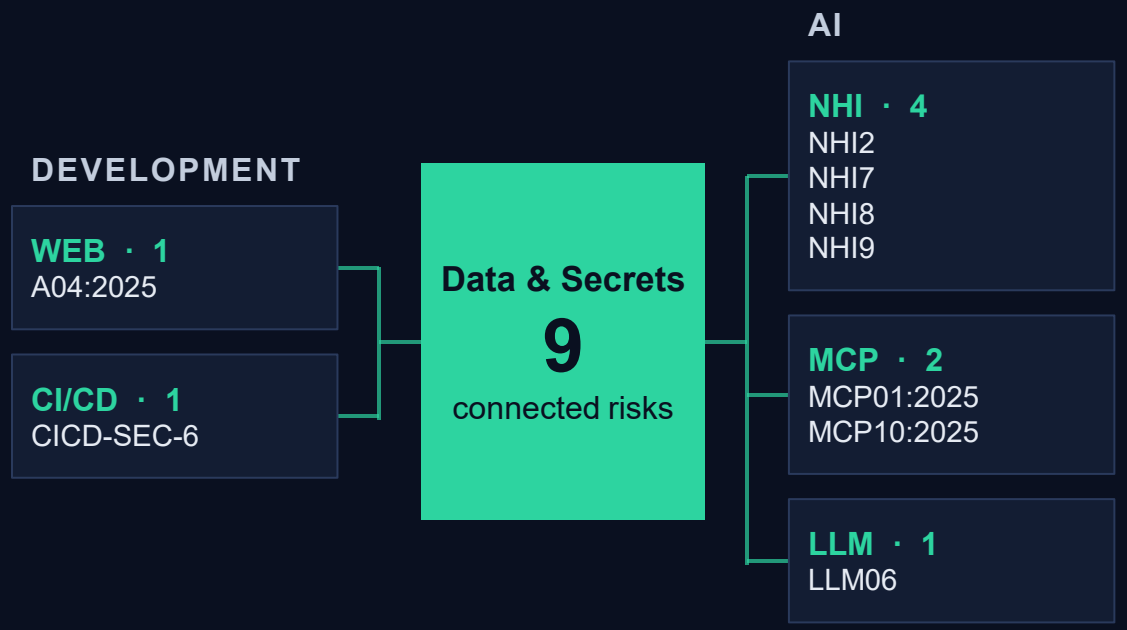
03

Protect the AI and tools supply chain

- Trusted model and tool sources; MCP allow-listing
- Least privilege for agents and tools
- Monitor third-party AI components

PRIORITIZE **Provenance + dependency/integration governance**

Data, Secrets & Credential Protection



DEVELOPMENT RISK · WEB + API + CI/CD — **2 connected**

Exposed data, tokens, keys or long-lived credentials turn one compromise into broad access.

- Minimize sensitive data
- Centralize secrets management
- Eliminate static credentials
- Encrypt sensitive data
- Prevent leakage
- Isolate environments

AI RISK · NHI + LLM + MCP + AGENTIC AI — **7 connected**

Prompts, context, outputs, memory, MCP and tools all become paths for data and secrets to leak.

- Minimize AI data exposure
- No embedded secrets
- Workload identities
- Short-lived scoped tokens
- Isolate identities & envs
- Protect telemetry
- Control agent data access

Prioritized mitigations

01

Secrets hygiene

- Secret scanning with push protection
- Eliminate hard-coded secrets

02

Centralize secrets management

- Store credentials in dedicated secret-management systems
- Monitor sensitive access

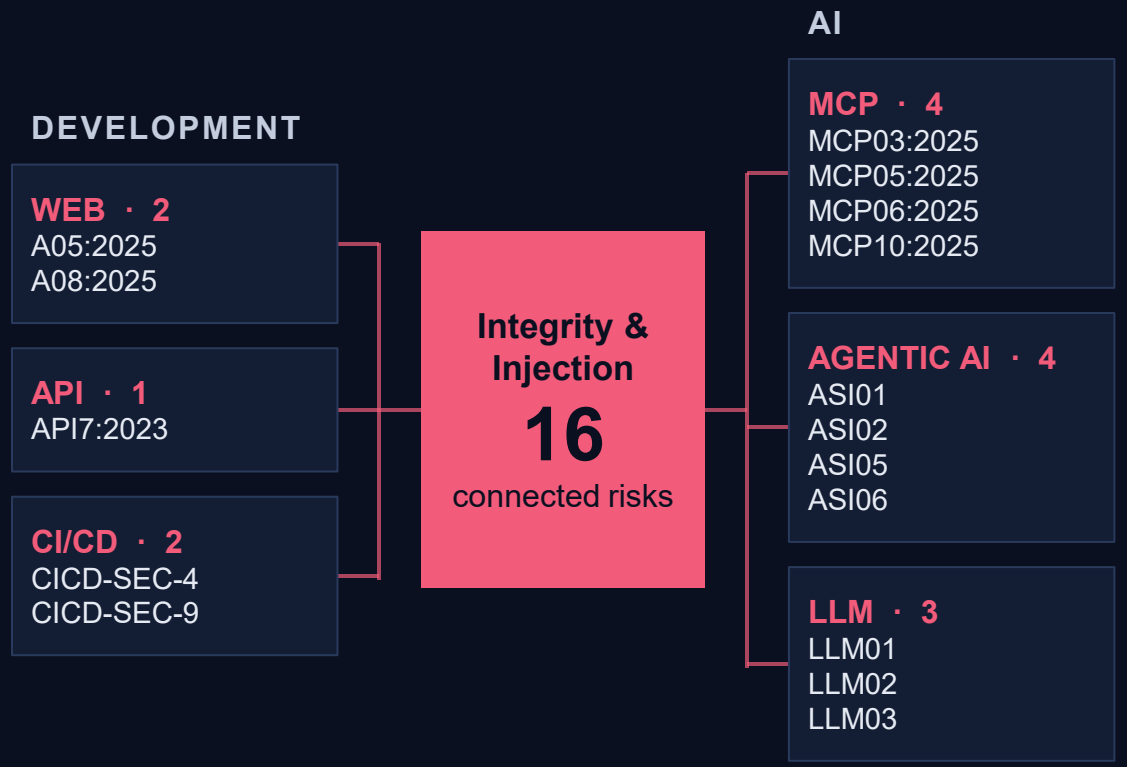
03

Understand the platform identity model

- Prefer identity over credentials
- Automate rotation, detect exposure and revoke exposed secrets fast

PRIORITIZE **Minimize + vault + rotate**

Integrity, Injection & Trust Boundaries



DEVELOPMENT RISK · WEB + API + CI/CD — **5 connected**

Untrusted input, responses, code or artifacts cross boundaries to hijack queries, builds or execution.

- Validate inputs
- Safe execution patterns
- Enforce trust boundaries
- Constrain execution
- Verify integrity
- Protect change flows
- Validate external services

AI RISK · NHI + LLM + MCP + AGENTIC AI — **11 connected**

Prompts, retrieved data, memory, tool descriptions and agent messages steer what AI decides or runs.

- AI content is untrusted
- Separate instructions & data
- Validate outputs first
- Constrain tools
- Protect context & memory
- Isolate execution
- Authorize sensitive actions
- Least privilege

Prioritized mitigations

01

Protect data and instruction integrity

- Enforce explicit trust boundaries
- Keep untrusted content out of control flow and privileged agent/tool instructions

02

Apply least privilege

- Limit the impact of successful injection
- Limit excessive agent autonomy across trust boundaries

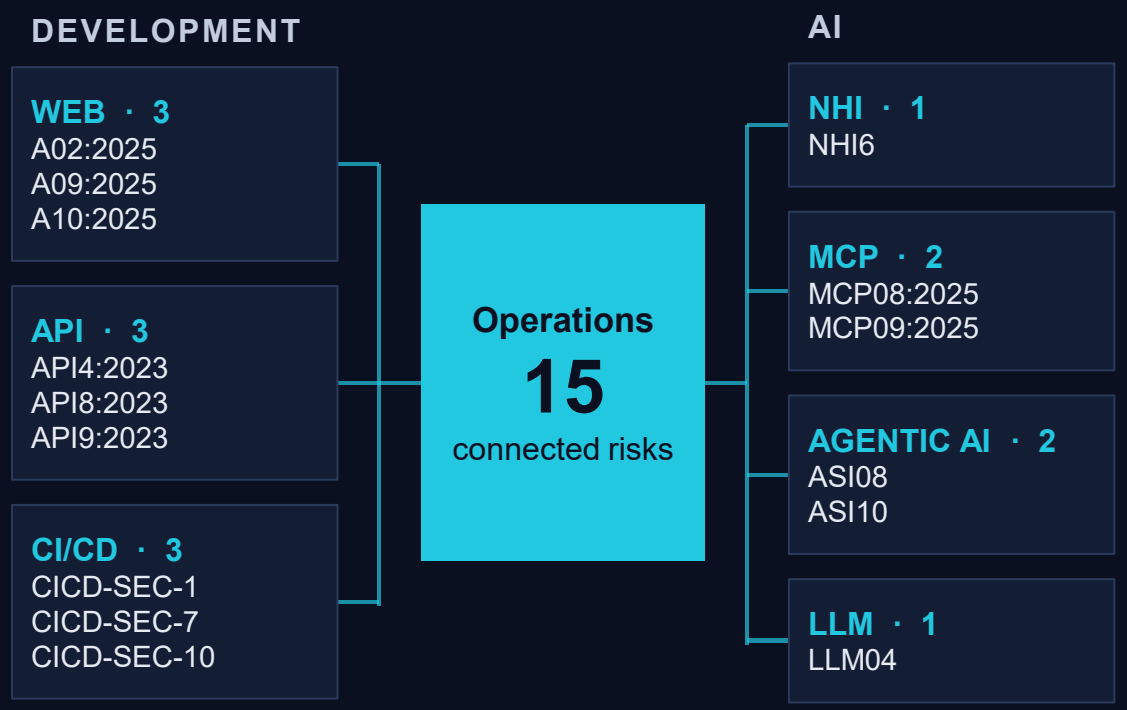
03

Monitor boundary violations

- Monitor sensitive access
- Log and alert on trust-boundary violations and anomalous agent/tool actions

PRIORITIZE **Validate + isolate + constrain execution**

Secure Operations, Visibility & Resilience



DEVELOPMENT RISK · WEB + API + CI/CD — **9 connected**

Misconfigured, uninventoried or unmonitored systems hide attacks and let failures spread.

- Standardize configurations
- Maintain inventory
- Centralize visibility
- Control resource usage
- Control change
- Fail safely
- Detect and respond

AI RISK · NHI + LLM + MCP + AGENTIC AI — **6 connected**

Poor visibility lets runaway consumption, shadow infrastructure and rogue agents go unnoticed.

- Inventory the AI estate
- Secure baselines
- Monitor behavior
- Constrain resources
- Govern lifecycle
- Contain failures
- Control high-impact actions
- Prepare for abnormal behavior

Prioritized mitigations

01

Centralize security logging

- Continuously monitor for threats
- Maintain end-to-end traceability

02

Implement incident detection and response

- Act on platform-provided alerts and known-bad activity
- Processes to investigate, contain, revoke, recover and learn

03

Secure configuration by default

- Define security controls by policy
- Design for failure and resilience

PRIORITIZE **Secure defaults + visibility + resilience**

TAKEAWAYS

The prioritization model

7 LISTS · 70 RISKS → 5 META RISKS

META RISK	PRIORITIZE
Identity & Access	Least privilege + strong identity
Supply Chain	Provenance + dependency/integration governance
Data & Secrets	Minimize + vault + rotate
Integrity & Injection	Validate + isolate + constrain execution
Operations	Secure defaults + visibility + resilience

THE FEEDBACK LOOP

Build reusable mitigation buckets
Policies + common controls: observability, logs, vaults, scanners, identity provider

Avoid checklist hell
No built-in feedback loop — just more steps

Reproduced risk = cost
Every repeat finding costs the fix, time and effort

Focus on defendable design
Do what you can with limited resources

OWASP SWITZERLAND

Thank you

Questions?

Dante Hollingsworth · Cloud Solution Architect, Microsoft
Ibraimo Djalo · Solution Engineer, Microsoft

